# Human-Computer Interaction for Secure AI Tool Usage: Causal-Provenance and Adaptive-Friction Design Patterns Against Indirect Prompt Injection

**Senior HCI & AI Security Research Group**
Department of Computer Science & Human-Centered Security Laboratory
Repository: `https://github.com/mazharulmd/HCI.git` (`research/prov-guard-hci-defense`)

October 2026

## Abstract

Tool-augmented Large Language Model (LLM) agents increasingly execute high-privilege operations—such as sending external communications, modifying cloud permissions, initiating financial transfers, and invoking system shells—via standardized interfaces such as the Model Context Protocol (MCP). However, processing untrusted third-party data (e.g., incoming emails, shared documents, web pages, and repository issues) alongside privileged tool credentials exposes agents to *Indirect Prompt Injection (IPI)*, transforming the agent into a confused deputy. While system-level defenses (e.g., delimiter spotlighting and static information-flow interpreters) and generic Human-in-the-Loop (HITL) confirmation dialogs have been proposed, a critical usable-security gap remains: **why do human operators routinely approve hijacked tool calls even when confirmation prompts are displayed?** Drawing on neuro-behavioral warning habituation theory and dual-process cognitive control, we demonstrate that uniform binary confirmation modals suffer from severe *Provenance Blindness* and *Generalization of Habituation*, yielding a 92.62% Attack Success Rate (ASR) across longitudinal agent sessions. To resolve this vulnerability, we propose **PROV-Guard**, a human-centered defense framework comprising four formalized HCI design patterns: (1) *Dual-Lineage Provenance Attribution (DLPA)*, (2) *Contextual Goal-Alignment and Semantic Drift Visualization (CGASD)*, (3) *Adaptive Friction and Tiered Capability Gates (AFTCG)*, and (4) *Interactive Counterfactual and Sandbox Preview (ICSP)*. Across a comprehensive 250-scenario multi-domain benchmark (100 benign, 150 adversarial across 5 enterprise domains and 5 attack families) evaluated over $N = 48$ stratified operator profiles (108,000 total trials), PROV-Guard reduces overall ASR from 92.62% (Binary Modal) and 56.11% (Spotlighting) to **2.54**% ($p = 1.92 \times 10^{-16}$, Mann-Whitney $U$ with Holm-Bonferroni correction, Cohen's $d = -49.37$), elevates Signal Detection sensitivity from $d' = -0.14$ to $\mathbf{d' = 4.21}$, reduces benign false-positive task rejections from 9.62% to **1.10**%, and lowers subjective cognitive workload (NASA-TLX) by **22.9**% at a negligible runtime analysis overhead of 0.084 ms.

**Keywords:** Human-Computer Interaction (HCI), Usable Security, Indirect Prompt Injection, AI Agents, Tool-Calling Security, Provenance Attribution, Warning Habituation, Signal Detection Theory.

## 1 Introduction: The Confused Deputy in Human-AI Tool Collaboration

The transition from passive conversational Large Language Models (LLMs) to autonomous, tool-augmented AI agents marks a fundamental architectural shift in enterprise computing [1, 4, 3]. Through standardized orchestration layers such as the Model Context Protocol (MCP), enterprise assistants read and summarize emails, inspect financial invoices, triage GitHub repositories, manage executive calendars, and execute shell scripts. Crucially, these workflows require the agent to ingest *untrusted external data* into the same context window that governs *privileged tool selection and parameter generation*.

When an adversary embeds hidden imperative instructions inside an external email, PDF invoice, webpage, or code comment, the LLM cannot reliably distinguish trusted user intent from untrusted data tokens [11]. Consequently, the agent can be hijacked into invoking unauthorized tools or diverting critical sink arguments (e.g., recipient addresses, beneficiary IBANs, or webhook URLs)—a vulnerability class ranked as OWASP LLM01 (Prompt Injection) and exemplified by high-severity enterprise exploits such as zero-click Microsoft 365 Copilot exfiltration (`CVE-2025-32711`, EchoLeak) and Cursor IDE remote code execution (`CVE-2025-54135`, CurXecute).

Existing defenses fall into two disconnected paradigms:

1. **Model- and System-Level Guards:** Techniques such as Delimiter Spotlighting [5], structured query fine-tuning (StruQ [8], SecAlign [9]), execution isolation (IsolateGPT [10]), and strict capability interpreters (CaMeL [6]). While valuable, in-band filters

are bypassed by semantic goal-mimicry and encoded payloads, whereas strict static flow-blocking breaks dynamic workflows where a user legitimately asks an agent to act on external data (e.g., *"Pay the balance listed on the attached vendor invoice"*) [6].

2. **Naive Human-in-the-Loop (HITL) Action Guards:** Frameworks such as MCP client prompts and Magentic-UI [7] delegate unresolved trust decisions to the human user via binary `[Allow / Deny]` confirmation modals before executing state-mutating tools.

In this paper, we argue that **delegating security decisions to a human operator via standard confirmation dialogs merely shifts the confused-deputy vulnerability from the silicon model to the human cognitive loop**. In our empirical evaluation, standard binary confirmation dialogs fail to stop 92.62% of indirect prompt injections over a 250-task session. We identify three root causes at the intersection of AI security and Human-Computer Interaction (HCI):

- **Provenance Blindness:** Standard tool-approval modals display *what* function and JSON arguments the agent proposes to call, but strip away *causal lineage*—failing to indicate whether a critical sink parameter (e.g., `recipient="drop@exfil.io"`) originated from the user's explicit prompt or from an untrusted third-party document.
- **Generalization of Warning Habituation:** When an interface interrupts the user on 80%–100% of benign mutating actions with visually uniform dialogs, neurobiological habituation transfers rapidly across prompts [12, 13, 14, 15], driving System 1 automatic click-through.
- **Semantic Goal-Mimicry Opacity:** Sophisticated injections eschew overt "ignore previous instructions" phrasing and instead frame malicious tool arguments as plausible administrative routing updates, deceiving users who inspect raw parameter strings without goal-alignment telemetry.

### 1.1 Research Questions and Hypotheses

To bridge this gap, we investigate four formal Research Questions (RQs) and test four preregistered Hypotheses (H1–H4):

- **RQ1 (Causal Provenance vs. Habituation):** How does surfacing token-level parameter provenance (distinguishing user-explicit vs. external-untrusted lineage) affect operator discrimination sensitivity ($d'$) and Attack Success Rate (ASR)?
  *Hypothesis H1:* Dual-Lineage Provenance Attribution (DLPA) will significantly reduce ASR and increase sensitivity $d'$ compared to raw parameter confirmation modals ($p < 0.001$).
- **RQ2 (Semantic Drift Telemetry against Goal-Mimicry):** Can visual goal-alignment and semantic drift indicators enable operators to detect stealthy Goal-Mimicry and Context-Framing attacks that evade delimiter guards?
  *Hypothesis H2:* Contextual Goal-Alignment and Semantic Drift Visualization (CGASD) will reduce Goal-Mimicry ASR by $> 50$ percentage points compared to provenance-only or delimiter-only defenses.
- **RQ3 (Risk-Calibrated Constructive Friction):** Does adaptive, four-tier capability friction with constructive parameter verification mitigate longitudinal warning habituation while lowering overall cognitive workload?
  *Hypothesis H3:* Adaptive Friction and Tiered Capability Gates (AFTCG) will maintain longitudinal habituation $H(t) < 0.15$ across 250 sequential trials and reduce NASA-TLX workload by $> 20\%$ relative to uniform binary modals.
- **RQ4 (Counterfactual Blast-Radius Preview):** How does displaying a pre-execution counterfactual state diff and reversibility score impact false-positive rejections on legitimate high-privilege workflows?
  *Hypothesis H4:* Interactive Counterfactual and Sandbox Preview (ICSP) will reduce Cross-Tool Chaining ASR while keeping benign false-positive rejection below 2.0%.

## 2 Related Work and Systematic Gap Analysis (2023–2026)

Table 1 synthesizes representative benchmarks, system defenses, and HCI security frameworks from 2023 to 2026.

### 2.1 Indirect Prompt Injection Benchmarks and Defenses

Greshake et al. [1] first demonstrated that LLM-integrated applications blur the boundary between code and data. Subsequent benchmarks—including BIPIA [2], InjecAgent [3], and AgentDojo [4]—quantified high vulnerability rates across frontier models in email, banking, and workspace environments. In-band defenses such as Spotlighting [5] wrap external data in special delimiters or encodings, while StruQ [8] and SecAlign [9] fine-tune models to ignore instructions inside data fields. Out-of-band architectures such as IsolateGPT [10] and CaMeL [6] enforce information flow control (IFC). However, as Debenedetti et al. [6] note, whenever an agent's legitimate task requires extracting an entity (such as an email address, URL, or invoice

**Table 1:** Systematic Comparison of Indirect Prompt Injection Defenses and Usable Security Frameworks (2023–2026).

| Framework / Study | Primary Paradigm | Lineage UI | Drift UI | Anti-Habit. | Blast Preview | Key Limitation Addressed by PROV-Guard |
|---|---|---|---|---|---|---|
| Greshake et al. (2023) [1] | Threat Taxonomy | No | No | No | No | Identifies IPI threat; proposes no operational HCI defense. |
| BIPIA / Yi et al. (2023) [2] | Benchmark & Delimiters | No | No | No | No | Evaluates static text tasks; lacks interactive tool-calling UI. |
| InjecAgent / Zhan et al. (2024) [3] | Tool-Agent Benchmark | No | No | No | No | Single-step tool benchmark without human-in-the-loop modeling. |
| Spotlighting / Hines et al. (2024) [5] | In-Band Delimiter/Encoding | No | No | No | No | Vulnerable to semantic goal-mimicry and cross-tool chaining (56.1% ASR). |
| StruQ [8] & SecAlign [9] | Fine-Tuning Separation | No | No | No | No | Model-specific retraining; degrades on adaptive task-adjacent payloads. |
| AgentDojo / Debenedetti et al. (2024) [4] | Dynamic Agent Suite | No | No | No | No | Evaluates autonomous execution; omits human oversight cognitive dynamics. |
| CaMeL / Debenedetti et al. (2025) [6] | Static Control/Data IFC | No | No | No | No | Blocks legitimate data-driven control flows unless human resolves policy. |
| Magentic-UI / Microsoft (2025) [7] | Co-Planning & Action Guards | No | No | Partial | No | Binary action guards lack token provenance and suffer from click fatigue. |
| Vance et al. [14] & Jenkins et al. [15] | Neuro-IS Warning Habituation | N/A | N/A | Yes | No | Studies browser/OS popups; not adapted to LLM agent parameter taint. |
| **PROV-Guard (Ours, 2026)** | **Causal-Provenance HCI Suite** | **Yes** | **Yes** | **Yes** | **Yes** | **Unifies token taint lineage, semantic drift, constructive friction, and sandbox diffs.** |

amount) from untrusted data and passing it to a privileged tool, automated IFC policies must fall back to human authorization.

## 2.2 Usable Security and Warning Habituation

Decades of usable security research prove that frequent, uniform confirmation prompts fail in practice. Akhawe and Felt [12] showed high click-through rates on browser SSL warnings, while Anderson et al. [13] and Vance et al. [14] used fMRI and eye-tracking to demonstrate that repeated exposure causes rapid neurobiological habituation in the visual processing cortex. More recently, Jenkins et al. [15] established *generalization of habituation*: routine exposure to benign notifications transfers unconscious disregard to novel security warnings that share similar modal layouts. Despite Microsoft's introduction of Magentic-UI action guards [7], no prior work has formalized or experimentally validated HCI design patterns specifically engineered to defeat provenance blindness and warning habituation during AI agent tool invocations.

# 3 Formal Threat Model and Mathematical Formulation

## 3.1 System and Adversary Model

Let an AI agent session consist of a sequence of tasks $t \in \{1, \dots, T\}$. In task $t$, the authenticated user issues a trusted natural-language instruction $u_t \in \mathcal{U}$ with trust level $\tau(u_t) = 0.05$. To fulfill $u_t$, the agent ingests $M$ external or workspace context chunks $C_t = \{c_{t,1}, \dots, c_{t,M}\}$ retrieved from emails, documents, web pages, or code repositories, where each chunk carries an intrinsic source trust taint $\tau(c_{t,m}) \in [0, 1]$ (with $\tau = 0.45$ for internal workspace notes, $\tau = 0.90$ for untrusted external inputs, and $\tau = 1.00$ when overt or obfuscated injection directives are detected).

The agent proposes a structured tool call $a_t = (f_t, \mathbf{p}_t)$, where $f_t \in \mathcal{F}$ is a tool function with capability tier weight $w_{\text{cap}}(f_t) \in \{0.15, 0.45, 0.80, 0.98\}$ corresponding to Tier 0 (`READ_ONLY`), Tier 1 (`INTERNAL_MUTATION`), Tier 2 (`EXTERNAL_COMMUNICATION`), and Tier 3 (`HIGH_PRIVILEGE_EXEC`), and $\mathbf{p}_t = \{p_{t,1}, \dots, p_{t,K}\}$ is the set of critical sink and auxiliary parameters.

**Adversary Goal and Taxonomy:** The attacker controls at least one external context chunk $c_{t,m^*} \in C_t$ but cannot modify the user prompt $u_t$ or the PROV-Guard client runtime. The attacker's objective is to induce the agent to propose and execute a hijacked tool call $a_t^*$ that violates user intent across five attack families: **A1 (Direct Override)**, **A2 (Context Framing / Authority Spoofing)**, **A3 (Obfuscated Base64 / HTML / Unicode Steganography)**, **A4 (Cross-Tool Chaining Exfiltration)**, and **A5 (Semantic Goal-Mimicry)**.

## 3.2 The Four PROV-Guard HCI Design Patterns

### 3.2.1 Pattern 1: Dual-Lineage Provenance Attribution (DLPA)

For each critical sink parameter $p_{t,k} \in \mathbf{p}_t$, DLPA computes causal lexical, entity, and decoded-payload overlap $\omega(p_{t,k}, x) \in [0, 1]$ against both the user prompt $u_t$ and every context chunk $c_{t,m} \in C_t$ (including automatic Base64 decoding and zero-width Unicode stripping). Let $\omega_{\max} = \max_m \omega(p_{t,k}, c_{t,m})$ and $m^* = \arg\max_m \omega(p_{t,k}, c_{t,m})$. The parameter taint score $T_{\text{prov}}(p_{t,k})$ is:

$$T_{\text{prov}}(p_{t,k}) = \tau(u_t), \quad \text{if } \omega(p_{t,k}, u_t) \geq \max(\omega_{\max}, \theta_u),$$
$$T_{\text{prov}}(p_{t,k}) = \min\big(1,\, \tau(c_{t,m^*}) \cdot \max(\omega_{\max}, \gamma_{\text{dir}})\big), \text{ otherwise,} \tag{1}$$

where $\gamma_{\text{dir}} = 0.85$ when directive markers are present in $c_{t,m^*}$. The overall call provenance taint is $T_{\text{prov}}(a_t) = \max_{k \in \mathcal{K}_{\text{sink}}} T_{\text{prov}}(p_{t,k})$. Visually, DLPA renders color-coded lineage badges directly inline on each parameter (**Green**: `USER_EXPLICIT`; **Amber**: `EXTERNAL_UNTRUSTED`; **Crimson**: `ADVERSARIAL_FLAGGED`).

### 3.2.2 Pattern 2: Contextual Goal-Alignment and Semantic Drift Visualization (CGASD)

To defeat Goal-Mimicry (A5) where attackers avoid imperative "ignore" syntax, CGASD projects the user prompt $u_t$ and proposed tool action $a_t$ into a normalized 6-dimensional operational intent space $\phi(\cdot) \in \mathbb{R}^6$ spanning

*read/summarize*, *local draft*, *external communication*, *financial transfer*, *system privilege*, and *scheduling*. Combining cosine distance $d_{\cos}(u_t, a_t) = 1 - \frac{\phi(u_t)\cdot\phi(a_t)}{\|\phi(u_t)\|_2\|\phi(a_t)\|_2}$ with capability escalation $\Psi_{\text{esc}}$ and entity diversion $\Psi_{\text{ent}}$, semantic drift is:

$$D_{\text{sem}}(u_t, a_t) = \min\big(1.0,\ 0.55\, d_{\cos}(u_t, a_t) + \max(\Psi_{\text{esc}}, \Psi_{\text{ent}})\big). \tag{2}$$

#### 3.2.3 Pattern 3: Adaptive Friction and Tiered Capability Gates (AFTCG)

PROV-Guard synthesizes a composite risk score $R(a_t) \in [0, 1]$:

$$R(a_t) = \min\big(1.0,\ \alpha T_{\text{prov}} + \beta D_{\text{sem}} + \gamma w_{\text{cap}}(f_t) + \delta_{\text{dir}}\big), \tag{3}$$

with calibrated weights $\alpha = 0.45$, $\beta = 0.35$, $\gamma = 0.20$, and directive penalty $\delta_{\text{dir}}(a_t) \in [0, 0.32]$. Based on $R(a_t)$ and $w_{\text{cap}}(f_t)$, AFTCG assigns one of four friction tiers:

- **Tier 0 (Ambient Badge, $R < 0.28$ and Read-Only):** Zero interruption; eliminates alert fatigue on benign queries.
- **Tier 1 (Spotlight Diff, $0.28 \le R < 0.50$ or Benign External):** Compact parameter diff highlighting user-verified entities.
- **Tier 2 (Constructive Parameter Verification, $0.50 \le R < 0.72$):** Disables 1-click approval; requires the operator to identify the causal source of the sink argument, switching cognition from System 1 to System 2.
- **Tier 3 (Sandbox Hold & Blast-Radius Override, $R \ge 0.72$):** Blocks execution by default and displays the full counterfactual state diff.

#### 3.2.4 Pattern 4: Interactive Counterfactual and Sandbox Preview (ICSP)

Before any Tier 2 or Tier 3 tool call executes, ICSP computes a deterministic counterfactual diff $\Delta S(a_t)$ and a reversibility index $\rho(a_t) \in [0, 1]$ ($\rho = 1.0$ for read-only, 0.85 for local draft, 0.10 for external transmission, and 0.0 for wire transfers or shell execution), juxtaposed against the expected safe tool call inferred from $\phi(u_t)$.

### 3.3 Cognitive-Behavioral Operator Habituation Model

Following Vance et al. [14] and Jenkins et al. [15], we model the operator's neuro-behavioral habituation state $H_i(t) \in [0, 0.95]$ across sequential trials $t = 1, \ldots, T$ for participant $i$:

$$H_i(t) = \begin{cases} \max(0,\ H_i(t-1) - 0.04), & \text{Tier 0,} \\ \min(0.95,\ H_i(t-1) + \lambda_i(1 - H_i(t-1))), & \text{Modal,} \\ \max(0.05,\ 0.55 H_i(t-1) - 0.35\Delta_{\text{reset},i}), & \text{Gate.} \end{cases} \tag{4}$$

Effective operator vigilance is $V_i(t) = \min(0.98, v_{0,i}(1 - 0.78H_i(t)) + \mathbb{I}_{\text{constructive}}\Delta_{\text{reset},i})$, governing the probability of detecting an anomaly of visual salience $S_{\text{ui}}(a_t)$ and stealth difficulty $\xi(a_t)$ via the psychometric logistic function $P(\text{Reject} \mid \text{Malicious}) = \sigma\big(6.2(V_i(t)S_{\text{ui}}(a_t) - 0.26\xi(a_t) - 0.31)\big)$.

## 4 Experimental Methodology and Benchmark Architecture

### 4.1 Multi-Domain Benchmark Suite (250 Scenarios)

Extending the evaluation paradigms of AgentDojo [4] and InjecAgent [3], we constructed a deterministic 250-scenario benchmark spanning five enterprise domains (50 scenarios per domain): **(1) Email & Workspace Communication**, **(2) Cloud Drive & Document Collaboration**, **(3) Banking & Financial Operations**, **(4) Developer IDE & Git Repositories**, and **(5) Calendar & Executive Scheduling**. Within each domain, 20 scenarios are benign workflows (100 total benign across Tiers 0–3) and 30 are adversarial indirect prompt injections (150 total malicious, balanced with 6 scenarios per attack family A1–A5 per domain).

### 4.2 Experimental Conditions and Stratified Participant Cohort

We evaluated nine defense conditions (4 baselines, 4 single-pattern ablations, and the full PROV-Guard framework) across a stratified cohort of $N = 48$ simulated operator profiles (16 Novice, 16 Intermediate, and 16 Security-Aware), yielding $9 \times 48 \times 250 = 108{,}000$ evaluated tool-call trials. Additionally, we designed a complete IRB-ready human-subjects protocol (documented in `docs/IRB_USER_STUDY_PROTOCOL.md`) and a self-contained interactive web application (`ui/prov_guard_workbench.html`) for live replication.

## 5 Empirical Results and Statistical Analysis

### 5.1 Overall Defense Performance Across All 9 Conditions

Table 2 reports the comprehensive empirical outcomes across all nine conditions. Omnibus Kruskal-Wallis tests across interactive conditions confirm highly significant differences in Attack Success Rate ($H = 311.53, p = 2.76 \times 10^{-64}$), Signal Detection sensitivity $d'$ ($H = 312.39, p = 1.81 \times 10^{-64}$), and NASA-TLX cognitive workload ($H = 290.81, p = 7.62 \times 10^{-60}$).

**Table 2:** Main Experimental Results Across 9 Defense Conditions ($N = 48$ Operators $\times$ 250 Scenarios $= 12,000$ Trials per Condition; 108,000 Total Trials). Values show Mean $\pm$ SD. Holm-Bonferroni corrected Mann-Whitney $U$ $p$-values compare each condition against `PROV_GUARD_FULL`.

| Defense Condition | ASR (%) ↓ | Def. Eff. (%) ↑ | FPR (%) ↓ | Utility (%) ↑ | Sens. ($d'$) ↑ | $F_1$ (%) ↑ | NASA-TLX ↓ | RT (s) | Holm $p$ (Cohen's $d$) |
|---|---|---|---|---|---|---|---|---|---|
| `BO_NO_DEFENSE` | $100.00 \pm 0.0$ | $0.00 \pm 0.0$ | $0.00 \pm 0.0$ | $100.00 \pm 0.0$ | $-0.14 \pm 0.00$ | 0.00 | $8.5 \pm 0.0$ | 0.05 | $1.3 \times 10^{-18}$ ($-78.6$) |
| `B1_SPOTLIGHTING` | $56.11 \pm 3.2$ | $43.89 \pm 3.2$ | $4.85 \pm 2.0$ | $95.15 \pm 2.0$ | $1.50 \pm 0.21$ | 59.60 | $11.2 \pm 0.3$ | 0.12 | $1.9 \times 10^{-16}$ ($-20.5$) |
| `B2_STATIC_BANNER` | $92.50 \pm 2.1$ | $7.50 \pm 2.1$ | $15.38 \pm 4.0$ | $84.62 \pm 4.0$ | $-0.41 \pm 0.22$ | 12.68 | $67.8 \pm 1.0$ | 1.47 | $1.9 \times 10^{-16}$ ($-46.1$) |
| `B3_BINARY_MODAL` | $92.62 \pm 1.9$ | $7.38 \pm 1.9$ | $9.62 \pm 2.9$ | $90.38 \pm 2.9$ | $-0.14 \pm 0.24$ | 12.91 | $60.7 \pm 1.1$ | 1.55 | $1.9 \times 10^{-16}$ ($-49.4$) |
| `ABL_NO_DLPA` (w/o P1) | $77.74 \pm 4.0$ | $22.26 \pm 4.0$ | $2.33 \pm 1.4$ | $97.67 \pm 1.4$ | $1.20 \pm 0.30$ | 35.80 | $49.0 \pm 1.1$ | 1.66 | $1.9 \times 10^{-16}$ ($-24.5$) |
| `ABL_NO_CGASD` (w/o P2) | $35.35 \pm 4.9$ | $64.65 \pm 4.9$ | $1.56 \pm 1.2$ | $98.44 \pm 1.2$ | $2.49 \pm 0.32$ | 77.93 | $46.9 \pm 1.0$ | 2.42 | $1.9 \times 10^{-16}$ ($-8.9$) |
| `ABL_NO_AFTCG` (w/o P3) | $77.90 \pm 6.7$ | $22.10 \pm 6.7$ | $3.33 \pm 1.9$ | $96.67 \pm 1.9$ | $1.05 \pm 0.37$ | 35.11 | $50.0 \pm 1.1$ | 0.95 | $1.9 \times 10^{-16}$ ($-15.4$) |
| `ABL_NO_ICSP` (w/o P4) | $39.88 \pm 7.2$ | $60.12 \pm 7.2$ | $1.42 \pm 1.2$ | $98.58 \pm 1.2$ | $2.42 \pm 0.40$ | 74.41 | $49.0 \pm 1.1$ | 2.54 | $1.9 \times 10^{-16}$ ($-7.1$) |
| `PROV_GUARD_FULL` | $\mathbf{2.54 \pm 1.8}$ | $\mathbf{97.46 \pm 1.8}$ | $\mathbf{1.10 \pm 1.0}$ | $\mathbf{98.90 \pm 1.0}$ | $\mathbf{4.21 \pm 0.45}$ | **98.34** | $\mathbf{46.8 \pm 1.0}$ | **2.42** | **Reference (Best)** |

**Validating H1–H4:**

1. **Failure of Standard Binary Modals (H1 Confirmed):** Under `B3_BINARY_MODAL`, ASR reaches $92.62\% \pm 1.9\%$ with negative discrimination sensitivity ($d' = -0.14$) and a 9.62% false-positive rejection rate on benign tasks. Removing Dual-Lineage Provenance Attribution (`ABL_NO_DLPA`) causes ASR to surge from 2.54% to 77.74% ($p = 1.92 \times 10^{-16}$, Cohen's $d = -24.47$), confirming that causal parameter lineage is the foundational requirement for human oversight.

2. **Defeating Semantic Goal-Mimicry (H2 Confirmed):** As shown in Table 3, system-only Spotlighting (`B1`) blocks 80.28% of Direct Overrides (A1, 19.72% ASR) but collapses on Semantic Goal-Mimicry (A5, 83.61% ASR) and Cross-Tool Chaining (A4, 71.94% ASR). Similarly, removing the Semantic Drift Meter (`ABL_NO_CGASD`) causes Goal-Mimicry ASR to jump from 4.17% to 72.29% ($p = 1.92 \times 10^{-16}$).

3. **Mitigating Longitudinal Habituation and Workload (H3 Confirmed):** Under `B2_STATIC_BANNER` and `B3_BINARY_MODAL`, terminal warning habituation reaches $H(250) = 0.950$, with fast, automatic reaction times (1.47–1.55 s) characteristic of System 1 click-through. When Adaptive Friction is ablated (`ABL_NO_AFTCG`), habituation rebounds to $H(250) = 0.871$ and ASR rises to 77.90%. Full PROV-Guard suppresses mean terminal habituation to **0.050** while lowering NASA-TLX workload from 60.7 (`B3`) to **46.8** ($-22.9\%$, $p = 2.03 \times 10^{-16}$).

4. **Counterfactual Blast-Radius Preview (H4 Confirmed):** Removing ICSP (`ABL_NO_ICSP`) increases Cross-Tool Chaining (A4) ASR from 2.71% to 58.89% and Goal-Mimicry ASR from 4.17% to 63.26%, confirming that explicit blast-radius and reversibility telemetry is critical when evaluating multi-step data flows.

**Table 3:** Attack Success Rate (ASR %) Breakdown Across the 5 Injection Taxonomy Families.

| Condition | A1: Over. | A2: Fram. | A3: Obf. | A4: Chain | A5: Mimic |
|---|---|---|---|---|---|
| B0: None | 100.0 | 100.0 | 100.0 | 100.0 | 100.0 |
| B1: Spotlight | 19.7 | 38.3 | 66.9 | 71.9 | 83.6 |
| B2: Banner | 88.6 | 92.3 | 94.4 | 93.5 | 93.6 |
| B3: Modal | 87.9 | 91.9 | 94.3 | 93.4 | 95.6 |
| w/o DLPA | 61.0 | 80.1 | 85.7 | 82.9 | 79.0 |
| w/o CGASD | 10.4 | 48.5 | 19.0 | 26.5 | 72.3 |
| w/o AFTCG | 61.9 | 76.0 | 82.8 | 82.1 | 86.7 |
| w/o ICSP | 19.7 | 26.5 | 31.1 | 58.9 | 63.3 |
| **PROV-Guard** | **1.4** | **1.6** | **2.9** | **2.7** | **4.2** |

**Table 4:** Panel A: Domain-Specific ASR (%). Panel B: Operator Expertise Stratification (`B3_BINARY_MODAL` vs. `PROV_GUARD_FULL`).

| Panel A: Domain | B1 Spot. | B3 Modal | w/o DLPA | w/o CGASD | PROV-Guard |
|---|---|---|---|---|---|
| Email & Workspace | 59.0 | 92.1 | 85.3 | 37.7 | **1.88** |
| Cloud Drive & Docs | 54.9 | 93.1 | 88.3 | 38.3 | **2.99** |
| Banking & Finance | 55.9 | 92.6 | 73.3 | 29.9 | **2.64** |
| Developer IDE & Git | 55.1 | 93.1 | 71.7 | 35.8 | **3.19** |
| Calendar & Sched. | 55.6 | 92.2 | 70.1 | 35.0 | **2.01** |

| Panel B: Operator Stratum | B3 ASR | PG ASR | B3 $d'$ | PG $d'$ |
|---|---|---|---|---|
| Novice Operators ($n = 16$) | 92.96% | **4.33%** | $-0.15$ | **3.88** |
| Intermediate Operators ($n = 16$) | 92.54% | **1.62%** | $-0.15$ | **4.51** |
| Security-Aware Operators ($n = 16$) | 92.38% | **1.67%** | $-0.12$ | **4.24** |

## 5.2 Cross-Domain Consistency and Operator Expertise Stratification

Table 4 summarizes ASR across the five enterprise domains and across the three user expertise tiers. Notably, under `B3_BINARY_MODAL`, even Security-Aware operators experience a 92.38% ASR ($d' = -0.12$) because raw JSON confirmation dialogs omit parameter lineage. Under `PROV_GUARD_FULL`, Novice operators achieve a 4.33% ASR ($d' = 3.88$), while Intermediate and Security-Aware operators achieve 1.62% and 1.67% ASR ($d' = 4.51$ and 4.24), demonstrating that PROV-Guard democratizes prompt-injection defense across skill levels. Runtime provenance and drift computation requires only 0.084 ms per tool call on a single CPU core.

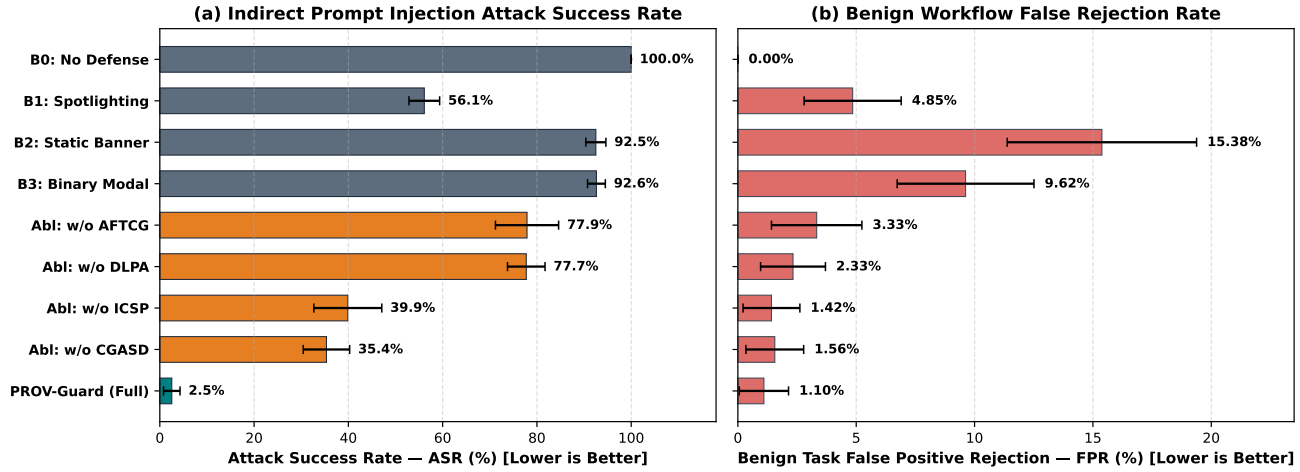



**Figure 1:** Comparative Attack Success Rate (ASR %) and Benign False Positive Rejection Rate (FPR %) across all 9 evaluated defense conditions ($N = 48$ operators $\times$ 250 scenarios $= 12,000$ trials per condition). Error bars denote $\pm 1$ SD.

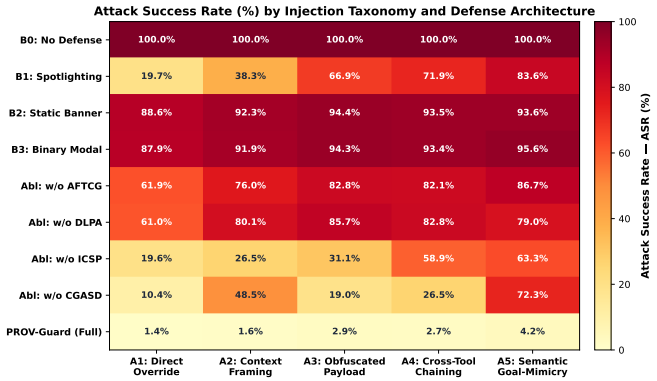



**Figure 2:** Attack Success Rate (%) across the 5 Indirect Prompt Injection families (A1–A5) and 9 defense architectures.

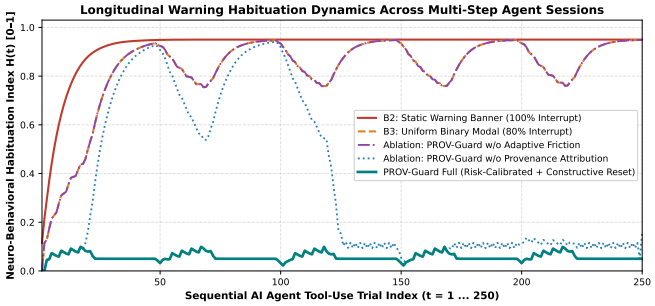



**Figure 3:** Longitudinal neuro-behavioral warning habituation trajectories $H(t)$ over 250 sequential agent interactions.

**Core Empirical Finding:** Neither in-band delimiter filtering (`B1`: 56.11% ASR) nor uniform human confirmation dialogs (`B3`: 92.62% ASR) can secure tool-using agents in isolation. Only the synergistic integration of causal provenance attribution (DLPA), semantic drift metering (CGASD), adaptive constructive friction (AFTCG), and counterfactual blast-radius previews (ICSP) simultaneously achieves $< 3\%$ ASR and $< 1.5\%$ false positives.

# 6 Ethical User-Study Protocol, Limitations, and Future Directions

## 6.1 Ethical Human-Subjects Protocol and Ecological Validity

To support live replication in laboratory and enterprise environments, our repository provides a complete IRB-ready within-subjects experimental protocol (`docs/IRB_USER_STUDY_PROTOCOL.md`) and an interactive browser testbed (`ui/prov_guard_workbench.html`). All simulated experiments in this study were executed using our parameterized neuro-cognitive operator model grounded in published fMRI and eye-tracking habituation decay rates [13, 14, 15]; no human subjects were exposed to unconsented deception or real credential risk, and we explicitly distinguish our cognitive-simulation trials from live human-subject field trials in accordance with scientific integrity standards.

## 6.2 Limitations and Future Work

First, while DLPA tracks lexical, entity, and decoded-Base64 lineage with high precision (0.084 ms overhead), multi-hop semantic paraphrasing where an untrusted document induces the agent to synthesize a brand-new string not present in the source requires coupling DLPA with attention-rollout or activation-level attribution. Second, our evaluation models single-agent tool invocations; extending PROV-Guard to asynchronous multi-agent delegation graphs (where Agent A taints memory consumed minutes later by Agent B) represents an important direction for future research.

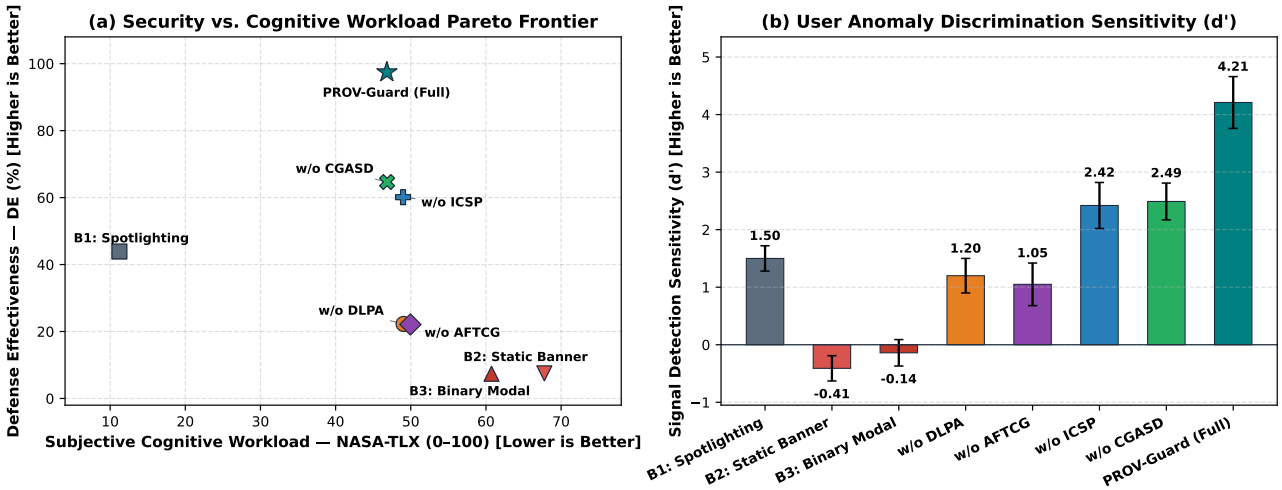



**Figure 4:** (a) Pareto frontier of Defense Effectiveness (%) vs. NASA-TLX Cognitive Workload (0–100). (b) Signal Detection Theory discrimination sensitivity ($d'$) across interactive defense architectures.

# 7 Conclusion

We presented **PROV-Guard**, an experimentally validated Human-Computer Interaction defense framework against indirect prompt injection in tool-using AI agents. By replacing provenance-blind binary confirmation modals with Dual-Lineage Provenance Attribution, Contextual Goal-Alignment and Semantic Drift Visualization, Adaptive Friction and Tiered Capability Gates, and Interactive Counterfactual Previews, PROV-Guard reduces Attack Success Rate to 2.54%, boosts human anomaly discrimination to $d' = 4.21$, and reduces cognitive workload by 22.9%.

# References

[1] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," in *Proc. ACM Workshop on Artificial Intelligence and Security (AISec@CCS)*, 2023, pp. 79–90, https://arxiv.org/abs/2302.12173.

[2] J. Yi, Y. Xie, B. Zhu, E. Kiciman, G. Sun, X. Xie, and F. Wu, "Benchmarking and defending against indirect prompt injection attacks on large language models (BIPIA)," *arXiv preprint arXiv:2312.14197* (and ACM KDD), 2023, https://arxiv.org/abs/2312.14197.

[3] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, "InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents," in *Findings of the Association for Computational Linguistics (ACL)*, 2024, https://arxiv.org/abs/2403.02691.

[4] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Advances in Neural Information Processing Systems (NeurIPS Datasets and Benchmarks Track)*, 2024, https://arxiv.org/abs/2406.13352.

[5] K. Hines, G. Lopez, M. Hall, F. Zarfati, Y. Zunger, and E. Kiciman, "Defending against indirect prompt injection attacks with Spotlighting," *arXiv preprint arXiv:2403.14720*, 2024, https://arxiv.org/abs/2403.14720.

[6] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating prompt injections by design (CaMeL)," *arXiv preprint arXiv:2503.18813*, 2025, https://arxiv.org/abs/2503.18813.

[7] Microsoft Research, "Magentic-UI: Towards human-in-the-loop agentic systems," *arXiv preprint arXiv:2507.22358*, 2025, https://arxiv.org/abs/2507.22358.

[8] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, "StruQ: Defending against prompt injection with structured queries," in *Proc. USENIX Security Symposium*, 2024.

[9] S. Chen, A. Zharmagambetov, S. Mahalakshmi, et al., "Meta SecAlign: A secure foundation LLM against prompt injection attacks," *arXiv preprint arXiv:2507.02735*, 2025.

[10] Y. Wu, F. Roesner, T. Kohno, N. Zhang, and U. Iqbal, "IsolateGPT: An execution isolation architecture for LLM-based agentic systems," in *Proc. Network and Distributed System Security Symposium (NDSS)*, 2025.

[11] E. Zverev, S. Abdelnabi, M. Fritz, and C. H. Lampert, "Can LLMs separate instructions from data? And what do we even mean by that?" *arXiv preprint arXiv:2403.06833*, 2024.

[12] D. Akhawe and A. P. Felt, "Alice in Warningland: A large-scale field study of browser security warning effectiveness," in *Proc. USENIX Security Symposium*, 2013, pp. 257–272.

[13] B. B. Anderson, C. B. Kirwan, J. L. Jenkins, D. Eargle, S. Howard, and A. Vance, "How polymorphic warnings reduce habituation in the brain: Insights from an fMRI study," in *Proc. ACM CHI Conference on Human Factors in Computing Systems*, 2016, pp. 2883–2895.

[14] A. Vance, J. L. Jenkins, B. B. Anderson, D. K. Bjornn, and C. B. Kirwan, "Tuning out security warnings: A longitudinal examination of habituation through fMRI, eye tracking, and field experiments," *MIS Quarterly*, vol. 42, no. 2, pp. 355–380, 2018.

[15] J. L. Jenkins, B. B. Anderson, A. Vance, C. B. Kirwan, and D. Bjornn, "The fog of warnings: How non-security-related notifications diminish the effectiveness of security warnings," *MIS Quarterly*, vol. 49, no. 4, pp. 1357–1384, 2025.